



*assess once,
reuse many
times*

a sketchnote guide

FedRAMP, explained in 15 sketches

How a cloud product earns the right to serve U.S. federal agencies, and how it keeps that right every month after.

Swipe to follow the lifecycle →

the big idea

What is FedRAMP?

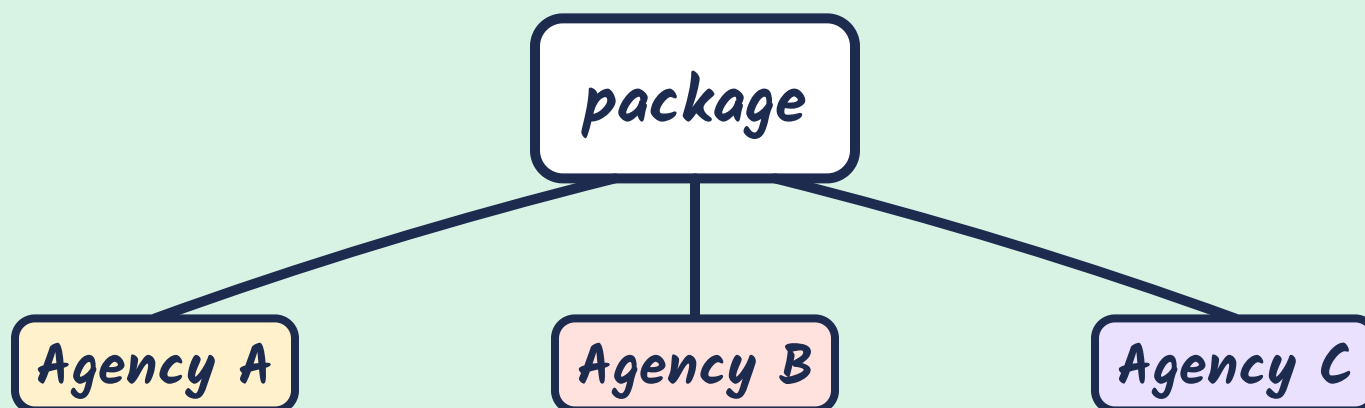
The Federal Risk and Authorization Management Program: one standard way to security-approve cloud services before agencies use them. Run by GSA.

Without it

Every agency audits the same product from scratch.
Twelve agencies means twelve audits.

With it

One security package, reviewed by one sponsor,
reused by every other agency.



Meet the cast



CSP

The Cloud Service Provider.
Builds the product,
implements the controls,
owns the fixes.



Agency + AO

The customer. Its Authorizing
Official accepts the risk and
signs the ATO.



3PAO

Accredited independent
assessor. Tests whether your
controls actually work.



FedRAMP PMO

Part of GSA. Writes the rules
and lists authorized products
on the Marketplace.

Say it like a pro

ATO = Authority to Operate SSP = System Security Plan

SAR = Security Assessment Report POA&M = Plan of Action &
Milestones

ConMon = Continuous Monitoring KSI = Key Security Indicator

how much risk?

Impact levels set the bar

Traditionally, a system is rated by how much damage a breach would cause. Each level maps to a baseline of NIST SP 800-53 controls.

L

Low

Limited harm. Public-facing, low-sensitivity data.

M

Moderate

most common

Serious harm. 300+ controls: access, logging, IR, config management.

H

High

Severe or catastrophic harm. Law enforcement, health, finance, emergency data.

2026 update: FedRAMP's Consolidated Rules replace the Low / Moderate / High labels with certification classes A through D.

The ATO lifecycle

Five phases. The first four get you in the door. The fifth never ends.

1

Prepare

scope, hosting, gap check



2

Document

how each control works



3

Assess

3PAO tests everything



4

Authorize

agency accepts the risk



5

Monitor

monthly, forever

phase 1: prepare

Decisions that set your cost



Draw a tight boundary

Everything inside must meet every control. Keep corporate IT out and map every data flow.



Inherit what you can

Build on an already-authorized IaaS and it covers physical and infrastructure controls for you.

Your app & data ← you

Platform & OS ← shared

Facilities & hardware ← inherited



Run a gap assessment

Compare today's state to the baseline before an assessor does. Gaps are cheapest to fix now.

Prove how it works

On Rev5, the heart of the package is the **System Security Plan**: a description of how every control is implemented.

Typical package contents

SSP

Incident response plan

Config mgmt plan

Contingency plan

Inventory

Policies

The engineer's shortcut: docs as code

Terraform



OSCAL



Package

OSCAL is a machine-readable format for security documentation. Generate it from the system and it stays current.

On the 20x path

Long narratives give way to Key Security Indicators, validated automatically against the running system.

The 3PAO shows up

1

Plan

Security Assessment Plan: what gets tested and how.



2

Test

Interviews, evidence review, vulnerability scans, penetration testing.



3

Report

Security Assessment Report lists every finding by severity.

Findings that stay open go on the POA&M

What's wrong, how you'll fix it, and by when.

High

Moderate

Low

A human signs off on risk

The agency's Authorizing Official reviews the SSP, the SAR, and the POA&M, then decides whether the remaining risk is acceptable.



ATO granted

You're listed on the FedRAMP Marketplace. Other agencies can reuse your package.



Sent back

Open high findings are the classic blocker. Fix them before the report.

Remember

An ATO isn't a certificate you frame. It's a promise to keep the system at that level every single month.

Continuous monitoring



Monthly

Vulnerability scans plus updated findings sent to the agency.



Annually

A 3PAO reassesses a set of controls.



Classic Rev5 remediation clock

30

days, high

90

days, moderate

180

days, low

The 2026 rules add new vulnerability detection and reporting rulesets.



Significant change? Ask first.

New external service or new data flow? Get approval before you ship it.

two paths

Rev5 vs FedRAMP 20x

Rev5

20x

Proof Control narratives

Key Security Indicators

Evidence Documents, screenshots

Machine-readable, automated

Checked Point in time + annual

Continuously

Fits Sponsored work already underway, self-run infrastructure

Cloud-native, IaC-heavy stacks

Future Being retired

FedRAMP's recommended path

The shift in one line: stop describing your security, start proving it from the running system.

Already on Rev5?

Start planning the move to 20x now. FedRAMP recommends transitioning as quickly as possible.

The transition timeline

Jun 25, 2026

Consolidated Rules for 2026 finalized

Dec 7, 2026

Vulnerability detection & reporting rules due

Jan 1, 2027

Enforcement of the 2026 rules begins

Jun 11, 2027

No new Rev5 applications accepted

Dec 31, 2028

Existing Rev5 authorizations sunset

Source: FedRAMP Consolidated Rules for 2026. Dates can move; check fedramp.gov.

for engineers

Where DevSecOps fits

Compliance is becoming an engineering problem. These skills map straight onto it.



IaC

Terraform defines the boundary and doubles as evidence.



Policy as code

OPA or Kyverno enforce controls at deploy time.



Pipeline evidence

CI jobs validate KSIs on every run.



Automated scanning

Images, hosts, and dependencies scanned before and after release.



Drift detection

Config compliance checks catch changes nobody approved.



Dashboards

Findings, ages, and due dates visible to everyone.

avoid these

5 mistakes that cost months

1

Boundary too broad

Every extra system inherits every control.

2

Ignoring inheritance

Rebuilding controls your IaaS already covers.

3

Docs written once

A static SSP is wrong after the next deploy.

4

Open highs at review

The fastest way to get the package sent back.

5

Shipping before asking

Unreported significant changes put the ATO at risk.

your turn

Authorization is the start line, not the finish.

I built an interactive ATO simulator to practice these decisions, from boundary to six months of ConMon. Link in the comments.

Found this useful?



Repost for someone starting their FedRAMP journey



Follow Razi for more DevSecOps and cloud-native sketches